Data and Cyber Security Policy

1. Purpose

This Policy establishes TIIS's governance and operational requirements for protecting the confidentiality, integrity and availability of institutional information, digital assets and information systems. It supports lawful handling of personal information, reliable teaching and student services, cyber resilience and accountable risk management.

2. Scope

This Policy applies to Directors, officers, employees, sessional staff, students, contractors and third parties using or administering TIIS information or systems. It covers paper and electronic information, institutional devices, personal devices authorised for TIIS work, networks, cloud services, learning management systems, student and financial records, backups and outsourced platforms. Contracts must reflect relevant requirements where TIIS relies on external providers.

3. Legislative and governance framework

TIIS will comply with applicable law, including the Privacy Act 1988 (Cth) and Australian Privacy Principles where applicable, the Notifiable Data Breaches scheme where applicable, and relevant contractual and recordkeeping obligations. The Higher Education Standards Framework (Threshold Standards) 2021 and the TIIS Constitution, Governance Charter, Risk Management Framework, Privacy Policy and Records Management requirements inform governance and assurance. Australian Cyber Security Centre (ACSC) Essential Eight guidance is a risk-based benchmark, not a declaration of certification or achieved maturity.

4. Policy principles

- Risk-based and proportionate protection: prioritise controls according to information sensitivity, criticality and threats.
- Accountability: information and systems have designated business owners; operational responsibility does not remove Board oversight or statutory duties.
- Least privilege and need to know: provide only access needed for approved duties and revoke it promptly when no longer required.
- Security and privacy by design: assess risks before introducing or materially changing systems, data uses or suppliers.
- Resilience and improvement: test recovery, learn from incidents and monitor corrective actions.
- Confidential reporting and fairness: protect sensitive incident information and apply appropriate investigation and escalation processes.

5. Governance and responsibilities

Board of Directors	**Oversees material cyber and information risks, risk appetite, significant incidents, resources and assurance; approves this Policy.**
Audit and Risk Committee (ARC)	Provides Board-level review, challenge and assurance under its Terms of Reference; does not direct technical operations.

CEO	Accountable for implementation, resources, assignment of system owners, material risk decisions, escalation and management reporting.
IT Manager / designated IT service lead	Implements and monitors technical safeguards, identity controls, vulnerability management, backups, logging, supplier coordination and incident containment.
Quality and Compliance Manager / designated compliance officer	Provides second-line monitoring, regulatory and privacy coordination, corrective-action tracking and independent reporting within approved responsibilities.
Registrar and other information owners	Approve business access needs, ensure appropriate handling of student and other records, review access and advise on retention requirements.
Managers, staff and contractors	Use authorised systems, complete required training, protect credentials and promptly report suspected incidents.
Students	Follow acceptable-use requirements, protect accounts and report suspected compromise.

6. Data classification and handling

Confidential	**Personal and sensitive information, student records, non-public financial information, credentials and investigation records. Restrict access, protect transmission and storage, and share only for authorised purposes.**
Internal	Non-public teaching, administrative and operational materials. Share only with authorised users and approved partners.
Public	Information formally approved for publication, such as published research and marketing materials.

Information owners must identify appropriate classification, authorised recipients, retention periods and secure disposal requirements. Personal information must be collected, used, disclosed and retained consistently with applicable privacy law and TIIS policies. Sensitive records must not be copied into unapproved services or personal accounts.

7. Identity and access management

- Use named individual accounts, strong authentication and multi-factor authentication for confidential-data systems, administrator accounts and remote access, subject to documented technical exceptions and compensating controls.
- Apply role-based access, least privilege, separation of duties and approval by an authorised information owner.
- Review privileged access regularly and other access periodically, with risk-based frequency and documented evidence.
- Promptly disable access on departure, role change, contract end or suspected compromise; restrict shared accounts and document unavoidable exceptions.
- Protect passwords, recovery methods, service accounts and cryptographic keys; never share credentials.

8. Systems, devices and network security

- Maintain a proportionate inventory of critical systems, assets, data repositories and accountable owners.

- Apply supported software, security updates, malware protection, secure configuration, firewall and monitoring controls according to assessed risk.
- Restrict administrative privileges; manage vulnerabilities and remediate critical exposures promptly under documented priorities.
- Encrypt confidential information in transit and at rest where appropriate; protect portable media and mobile devices.
- Permit remote work and personal-device access only under approved security arrangements, including device protection and secure connections.
- Log and monitor security-relevant activity for critical systems, with access and retention controls.
- Assess new technology, integrations and material changes before deployment; document exceptions and approvals.

9. Backup, continuity and recovery

TIIS must maintain risk-based backups of critical information and systems, protected against unauthorised alteration or deletion. The IT lead must document backup frequency, storage protections, restoration responsibilities and recovery priorities with business owners. Restoration tests and business continuity exercises must occur periodically, with results, gaps and remediation recorded. Recovery arrangements must support continuity of enrolment, learning, assessment and essential administration.

10. Cyber incident and data breach response

Any person who suspects phishing, malware, lost devices, unauthorised access, data disclosure or service compromise must report promptly through the designated IT/security or management channel. Staff must not independently investigate or disclose sensitive incident details beyond authorised personnel.

The CEO must ensure an incident response process covering identification, triage, containment, evidence preservation, risk assessment, recovery, communications, root-cause analysis and lessons learned. The IT lead coordinates technical response; the designated privacy/compliance officer assesses privacy implications and applicable notification duties. Suspected eligible data breaches must be assessed and notified to the OAIC and affected individuals where the Notifiable Data Breaches scheme applies. Other contractual, regulatory or law-enforcement reporting must be considered case by case. Material incidents must be escalated promptly to the CEO and Board/ARC as appropriate.

11. Third-party, cloud and cross-border services

Before engaging or materially changing a provider handling TIIS data, the responsible owner must conduct proportionate due diligence on security, privacy, data location, access, subcontractors, service continuity and exit arrangements. Contracts should address confidentiality, incident notification, access controls, data return/deletion, subcontracting and audit or assurance rights as appropriate. Offshore storage or access is not automatically prohibited; cross-border disclosures must be assessed against applicable Australian Privacy Principles, contractual requirements and institutional risks before approval.

12. Awareness, acceptable use and emerging technologies

TIIS will provide appropriate induction and recurring cyber awareness training to staff and relevant contractors, with student guidance through induction and digital channels. Users must recognise phishing, secure devices, report incidents and comply with acceptable-use rules. Confidential or personal information must not be entered into public generative AI tools or other unapproved applications without documented authorisation and suitable safeguards.

13. Monitoring, assurance and records

The CEO must maintain proportionate reporting on material risks, incidents, access reviews, backup testing, vulnerabilities, supplier assurance, training and outstanding corrective actions. The Quality and Compliance function monitors compliance independently of day-to-day technical operations where practicable. Evidence, incident records and decisions must be securely retained in accordance with the TIIS Records Management and Privacy requirements.

14. Non-compliance and exceptions

Breaches may lead to access restriction, remedial training, contractual action or staff/student disciplinary processes, subject to applicable policies and procedural fairness. Exceptions to mandatory controls require a documented risk assessment, compensating controls, authorised approval, expiry/review date and escalation where material. No exception may override a legal obligation.

15. Review and related documents

This Policy must be reviewed at least annually and after significant cyber incidents, major system changes or material legislative/regulatory developments. The CEO coordinates review, with academic consultation where teaching or student systems are affected, and submits material changes to the Board. Related documents include the TIIS Privacy Policy, Risk Management Framework, Records Management Policy, IT Acceptable Use Policy, incident response and business continuity procedures, and supplier management arrangements (where adopted).

16. Document Control

Version	**2.0 —**
Policy category	Information Technology / Risk Management
Policy owner	Chief Executive Officer
Approval authority	Approved by EMT and to be reviewed by Board of Directors within three months.
Consultation	Executive Management Team; Academic Board for academic-system impacts
Review	Within Three Months or earlier after a significant incident or regulatory change
Supersedes	Version 1.0 Draft (16 March 2026),

17. Version control

Version	Status	Approval	Date
1.0 (2026)	1st draft	No	15 March 2026
2.0	Revised draft responding to BOD review.	Approved by EMT	24 October 2026

18. Implementation and approval matters

- Confirm designated IT lead, privacy officer, system owners and incident-reporting channels.
- Approve risk-based standards for MFA, patching, backup frequency, recovery objectives and access review cadence.
- Verify whether the Privacy Act and Notifiable Data Breaches scheme apply to TIIS and document any additional notification obligations.
- Confirm actual security controls and Essential Eight maturity before describing them as implemented.
- Maintain evidence of Board approval and communicate the effective version to all relevant users.